

Clasificación de incidentes segun severidad

Divier Jácamo Álvarez

Cetav La Libertad

Rol: Analista SOC L1

Fecha Martes 03/03/26

Clasificación de incidentes simulados segun severidad

Introducción

En la actualidad, la seguridad en instituciones sanitarias no se limita exclusivamente al ámbito clínico la transformación digital del sector salud ha incrementado la dependencia de sistemas electrónicos de historia clínica, plataformas de telepsiquiatría y bases de datos sensibles en consecuencia, los incidentes de ciberseguridad pueden impactar directamente en la continuidad asistencial y en la confidencialidad de los pacientes.

En una clínica de salud mental, la exposición indebida de información clínica o la interrupción de sistemas críticos puede generar daños éticos, legales y terapéuticos significativos. Por ello, la clasificación de incidentes debe integrar tanto eventos clínicos como eventos detectados por el SOC institucional.

Metodología de Validación

Se constituyó un comité técnico ampliado conformado por:

Psiquiatra jefe

Psicólogo clínico

Enfermero supervisor

Coordinador de calidad

Oficial de seguridad de la información

Analista del SOC

El proceso incluyó:

Revisión individual de incidentes clínicos y cibernéticos simulados.

Evaluación del impacto real o potencial en la seguridad del paciente y en la confidencialidad de datos.

Clasificación según criterios de severidad: leve, moderado y grave.

Validación por consenso técnico documentado.

Resultados de la Validación

1. Incidentes Leves

Clínicos:

Retraso menor en medicación sin repercusión clínica.

Ciberseguridad (SOC):

Intento fallido de acceso no autorizado bloqueado por firewall institucional.

Correo electrónico sospechoso identificado y neutralizado sin apertura por parte del usuario.

Validación: El equipo determinó que estos eventos no generaron daño ni compromiso de información sensible, por lo que se clasifican como leves.

2. Incidentes Moderados

Clínicos:

Administración incorrecta de dosis con efectos adversos temporales.

Autolesión superficial con intervención médica inmediata.

Ciberseguridad (SOC):

Acceso indebido interno a historia clínica sin autorización clínica justificada.

Interrupción temporal del sistema de registro electrónico durante una hora.

Validación: Se concluyó que estos incidentes implicaron daño temporal o riesgo significativo que requirió intervención técnica o clínica, clasificándose como moderados.

3. Incidentes Graves

Clínicos:

Intento de suicidio con traslado a unidad de cuidados intensivos.

Agresión física grave al personal.

Ciberseguridad (SOC):

Ataque de ransomware que cifró temporalmente bases de datos clínicas.

Filtración confirmada de datos sensibles de pacientes.

Validación: El comité clasificó estos eventos como graves debido a su impacto directo en la vida del paciente, la continuidad operativa y la confidencialidad institucional. Se recomendó activar protocolos de análisis causa-raíz, notificación regulatoria y plan de respuesta a incidentes críticos.

Discusión

La integración de la perspectiva clínica y de ciberseguridad permitió comprender que los

incidentes digitales pueden convertirse en riesgos indirectos para la salud mental del paciente, especialmente cuando comprometen la confidencialidad o interrumpen tratamientos.

El SOC desempeña un papel estratégico en la detección temprana de amenazas tecnológicas, mientras que el equipo clínico evalúa el impacto terapéutico la validación interdisciplinaria fortalece la gobernanza institucional y promueve una visión holística de la seguridad.

Conclusiones

La validación conjunta de incidentes clínicos y de ciberseguridad demuestra que la gestión de riesgos en salud mental debe abordarse desde un enfoque integral.

Se concluye que:

La clasificación por severidad es coherente y técnicamente sustentada.

Los incidentes del SOC pueden tener repercusiones clínicas indirectas.

La coordinación entre áreas clínicas y tecnológicas es esencial para garantizar la seguridad del paciente y la protección de datos

se recomienda institucionalizar comités mixtos de revisión de incidentes y fortalecer los protocolos de respuesta integral ante eventos críticos

Clasificación con el equipo tecnico

Introducción

En la actualidad, la seguridad en instituciones sanitarias no se limita exclusivamente al ámbito clínico la transformación digital del sector salud ha incrementado la dependencia de sistemas electrónicos de historia clínica, plataformas de telepsiquiatría y bases de datos sensibles en consecuencia, los incidentes de ciberseguridad pueden impactar directamente en la continuidad asistencial y en la confidencialidad de los pacientes.

En una clínica de salud mental, la exposición indebida de información clínica o la interrupción de sistemas críticos puede generar daños éticos, legales y terapéuticos significativos. Por ello, la clasificación de incidentes debe integrar tanto eventos clínicos como eventos detectados por el SOC institucional.

Metodología de Validación

Se constituyó un comité técnico ampliado conformado por:

Psiquiatra jefe

Psicólogo clínico

Enfermero supervisor

Coordinador de calidad

Oficial de seguridad de la información

Analista del SOC

El proceso incluyó:

Revisión individual de incidentes clínicos y cibernéticos simulados.

Evaluación del impacto real o potencial en la seguridad del paciente y en la confidencialidad de datos.

Clasificación según criterios de severidad: leve, moderado y grave.

Validación por consenso técnico documentado.

Resultados de la Validación

1. Incidentes Leves

Clínicos:

Retraso menor en medicación sin repercusión clínica.

Ciberseguridad (SOC):

Intento fallido de acceso no autorizado bloqueado por firewall institucional.

Correo electrónico sospechoso identificado y neutralizado sin apertura por parte del usuario.

Validación: El equipo determinó que estos eventos no generaron daño ni compromiso de información sensible, por lo que se clasifican como leves.

2. Incidentes Moderados

Clínicos:

Administración incorrecta de dosis con efectos adversos temporales.

Autolesión superficial con intervención médica inmediata.

Ciberseguridad (SOC):

Acceso indebido interno a historia clínica sin autorización clínica justificada.

Interrupción temporal del sistema de registro electrónico durante una hora.

Validación: Se concluyó que estos incidentes implicaron daño temporal o riesgo significativo que requirió intervención técnica o clínica, clasificándose como moderados.

3. Incidentes Graves

Clínicos:

Intento de suicidio con traslado a unidad de cuidados intensivos.

Agresión física grave al personal.

Ciberseguridad (SOC):

Ataque de ransomware que cifró temporalmente bases de datos clínicas.

Filtración confirmada de datos sensibles de pacientes.

Validación: El comité clasificó estos eventos como graves debido a su impacto directo en la vida del paciente, la continuidad operativa y la confidencialidad institucional. Se recomendó activar protocolos de análisis causa-raíz, notificación regulatoria y plan de respuesta a incidentes críticos.

Discusión

La integración de la perspectiva clínica y de ciberseguridad permitió comprender que los incidentes digitales pueden convertirse en riesgos indirectos para la salud mental del paciente, especialmente cuando comprometen la confidencialidad o interrumpen tratamientos.

El SOC desempeña un papel estratégico en la detección temprana de amenazas tecnológicas, mientras que el equipo clínico evalúa el impacto terapéutico. La validación interdisciplinaria fortalece la gobernanza institucional y promueve una visión holística de la seguridad.

Conclusiones

La validación conjunta de incidentes clínicos y de ciberseguridad demuestra que la gestión de riesgos en salud mental debe abordarse desde un enfoque integral.

Documentación de proceso de Clasificación

La clasificación de incidentes es una herramienta fundamental para la mejora continua en centros de salud. En el ámbito de una clínica de salud mental, los riesgos pueden surgir tanto en la atención como en el entorno digital.

Documentar el proceso de clasificación facilita la estandarización de criterios, minimiza la variabilidad en las decisiones y garantiza la trazabilidad en auditorías tanto internas como externas.

Objetivo del Proceso

Definir un procedimiento formal para identificar, analizar y clasificar incidentes según su gravedad (leve, moderado o grave), teniendo en cuenta:

Impacto en la seguridad del paciente.

Impacto en la continuidad del cuidado.

Impacto en la confidencialidad, integridad y disponibilidad de la información.

Alcance

Este procedimiento es aplicable a:

Personal clínico (psiquiatría, psicología, enfermería).

Personal administrativo.

Equipo de tecnologías de la información.

Analistas del SOC.

Descripción del Proceso de Clasificación

1. Identificación del Incidente

El incidente puede ser detectado por:

Personal asistencial durante la atención clínica.

Sistemas automatizados del SOC.

Informes de pacientes o de sus familiares.

Se registra inicialmente en el sistema institucional de informes de incidentes.

2. Registro y Documentación Inicial

Se recogen los siguientes elementos:

Fecha y hora del evento.

Área involucrada.

Descripción objetiva del hecho.

Personas afectadas.

Evidencia disponible.

En casos de ciberseguridad, se incluyen logs, capturas de alertas y análisis preliminar del SOC.

3. Análisis de Impacto

El equipo encargado evalúa el incidente considerando tres dimensiones:

a) Impacto Clínico

¿Se produjo daño físico o psicológico?

¿Fue necesaria una intervención médica o psiquiátrica?

¿Hay riesgo para la vida?

b) Impacto Operativo

¿Se interrumpió la atención?

¿Se vio afectada la continuidad del tratamiento?

c) Impacto en Seguridad de la Información

¿Se vieron comprometidos datos sensibles?

¿Hubo acceso no autorizado?

¿Se vio afectada la disponibilidad del sistema?

4. Clasificación por Severidad

La clasificación se basa en los siguientes criterios:

Incidente Leve

No causa daño o provoca un impacto mínimo que se puede revertir.

No pone en riesgo datos sensibles ni la continuidad en la atención.

Incidente Moderado

Causa daño temporal o requiere intervención clínica o técnica.

Puede implicar acceso indebido sin filtraciones externas.

Interrumpe temporalmente los sistemas.

Incidente Grave

Representa una amenaza para la vida, causan daño permanente o tienen consecuencias legales.

Compromete datos sensibles de los pacientes.

Afecta significativamente las operaciones institucionales.

5. Validación Interdisciplinaria

El incidente clasificado es revisado por un comité técnico comprendido por:

Representante clínico.

Coordinador de calidad.

Oficial de seguridad de la información.

Analista del SOC.

Se documenta el consenso en un acta formal.

6. Acciones Derivadas

Dependiendo de la gravedad:

Leve: Acción correctiva local y monitoreo.

Moderado: Plan de mejora específico y seguimiento documentado.

Grave: Activación del protocolo de crisis, análisis de causa raíz, notificación a las autoridades pertinentes y comunicación institucional.

Control y Seguimiento

Todos los incidentes clasificados se consolidan en un informe mensual de gestión de riesgos que incluye:

Estadísticas por tipo y gravedad.

Tendencias recurrentes.

Indicadores de rendimiento.

Recomendaciones preventivas.

El SOC, además, genera informes técnicos sobre amenazas detectadas y mitigadas.

Conclusiones

La documentación formal del proceso de clasificación permite:

Estandarizar la evaluación de incidentes clínicos y tecnológicos.

Asegurar coherencia en la toma de decisiones.

Fortalecer la cultura de seguridad institucional.

Mejorar la trazabilidad y el cumplimiento de normativas.

Referencias

Ewoh, P., & Vartiainen, T. (2024). *Vulnerability to cyberattacks and sociotechnical solutions for health care systems: Systematic review. Journal of Medical Internet Research*, 26. <https://www.jmir.org/2024/1/e46904>

Faridoon, A., & Kechadi, M. T. (2024). *Healthcare data governance, privacy, and security — A conceptual framework. arXiv*. <https://doi.org/10.48550/arXiv.2403.17648>

Kencana Sari, P., Handayani, P. W., Hidayanto, A. N., Yazid, S., & Aji, R. F. (2022). *Information security behavior in health information systems: A review of research trends and antecedent factors. Healthcare*, 10(12), 2531. <https://doi.org/10.3390/healthcare10122531>

Gomero, R., & Sánchez, D. (2024). *Ciberseguridad en servicios de apoyo al médico ocupacional de la ciudad de Lima: Estudio piloto. Revista Médica Herediana*, 35(1), 38–43. <https://doi.org/10.20453/rmh.v35i1.5298>

INCIBE. (2024). *Ciberseguridad en el sector salud: características, amenazas y recomendaciones*. <https://www.incibe.es/index.php/incibe-cert/blog/ciberseguridad-en-el-sector-salud-caracteristicas-amenazas-y-recomendaciones>